

Access Token User Role Missing Bug Documentation

Module:

Authentication / Role-Based Access Control (RBAC)

Issue Summary:

The system failed to correctly identify user roles from the access token.

request.user.role returned incorrect values and role_id was missing, causing permission failures.

Root Cause:

JWT payload contained correct role data, but Django REST Framework did not map custom fields (role, role_id) into request.user.

Constraint:

JWT generation and authentication logic could not be modified.

Solution:

Manual JWT decoding was implemented inside APIs.

Steps:

1. Extract token from Authorization header
2. Decode using SECRET_KEY
3. Read role, role_id, is_admin from payload

Access Control:

- client_admin: full access
- other roles: restricted to their role_id
- POST restricted to admin only

Additional Fixes:

- Synced ClientUser role with StaffUser role
- Extracted role_id via StaffUser
- Used is_admin fallback for client_admin

Outcome:

- Correct role detection

- Permissions API works
- No change required in JWT/auth system

Recommendation:

Use custom JWT authentication and unify role system in future.